

ITSIMPLERA INSTITUTE

RED TEAM INTERNSHIP

Assignment 6

Cybersecurity Concepts and Security Fundamentals



PREPARED BY

Amna Imtiaz

REGISTRATION NO.

REDBO1-2350

INSTRUCTOR

Talal Rehan

Date: 8 August 2026

1. Introduction

This report is submitted as the Week 06 assignment for the IT-Simplera Institute Cyber Security Analyst Internship Program. It documents the design, configuration, and administration of an enterprise Active Directory (AD) environment for a fictional organization, TechSecure Solutions, which employs 300 staff across five departments (HR, IT, Finance, Sales, and Management) and two branch offices.

The exercise covers Active Directory architecture and OU design, user and group planning with least-privilege access control, Group Policy security hardening, hands-on Windows Server administration, defensive network enumeration using Kali Linux, and a real-world authentication troubleshooting case study. Throughout, the report links each technical decision back to the CIA Triad (Confidentiality, Integrity, Availability) and to standard defense-in-depth practice.

All Kali Linux enumeration in this report was performed strictly within a personal, isolated virtual lab against systems owned by the author, in line with the assignment's ethical-use requirement.



2. Task 1 – Enterprise Active Directory Design

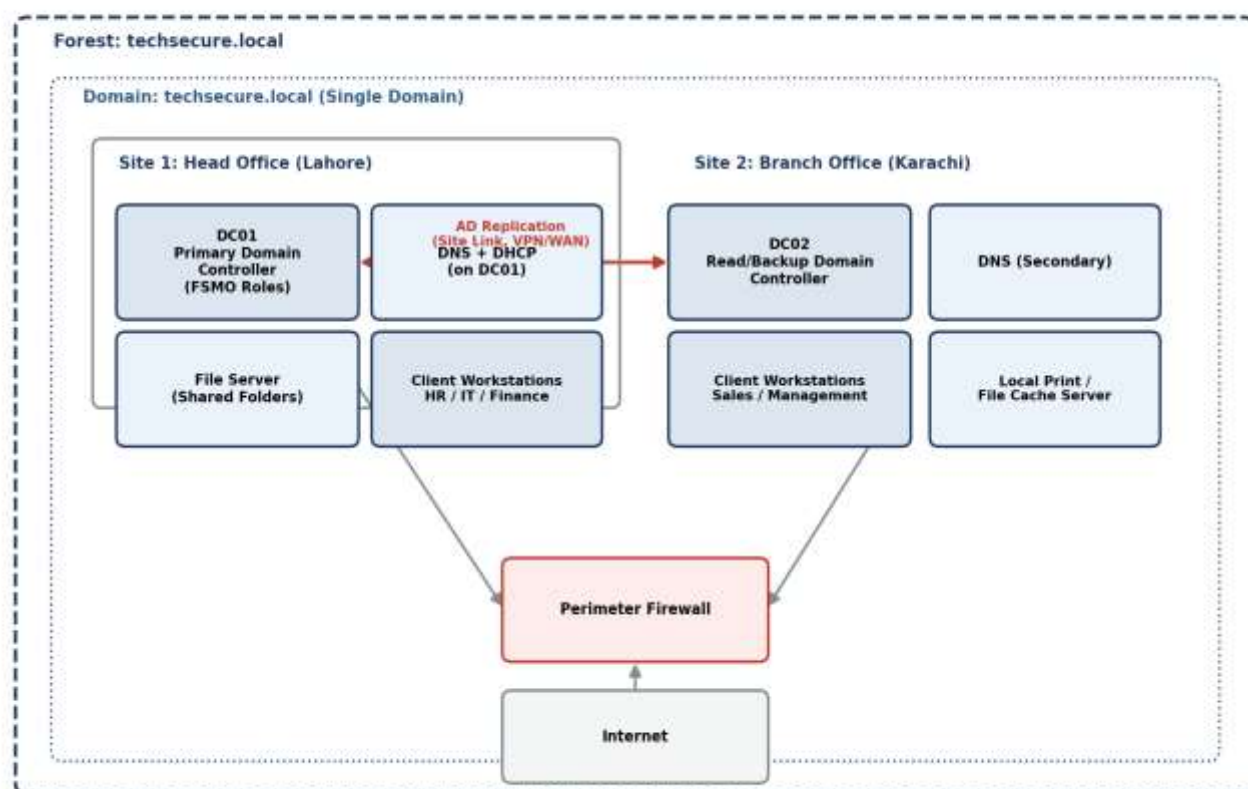
TechSecure Solutions requires an Active Directory infrastructure supporting 300 employees across five departments and two branch offices. The design below uses a single forest, single domain model with two Domain Controllers and eight Organizational Units.

2.1 Core Components

Component	Value / Detail
Forest	techsecure.local (1 forest)
Domain	techsecure.local (1 domain, single-domain model)
Domain Controllers	DC01 (Head Office – Lahore, holds all FSMO roles), DC02 (Branch Office – Karachi, backup/read DC)
Organizational Units (8)	HR, IT, Finance, Sales, Management, Servers, Workstations, Service Accounts
Branch Offices / Sites	Site 1 – Head Office (Lahore), Site 2 – Branch Office (Karachi), linked by a Site Link over VPN/WAN

2.2 Network & Site Topology

TechSecure Solutions - Forest, Site & Network Topology



2.3 Organizational Unit (OU) Structure

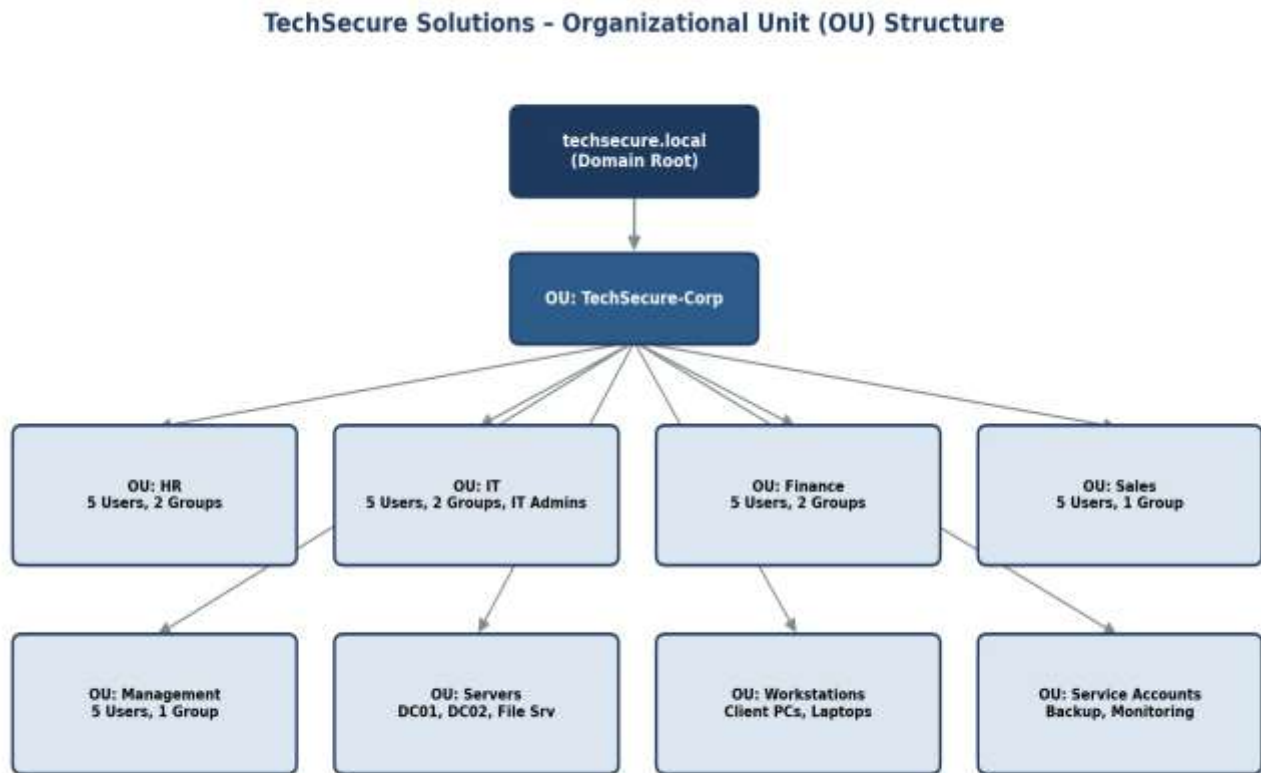


Figure 2: OU hierarchy under the domain root.

2.4 Authentication Flow: User → Domain Controller → File Server

Authentication Flow: User → Domain Controller → File Server (Kerberos)

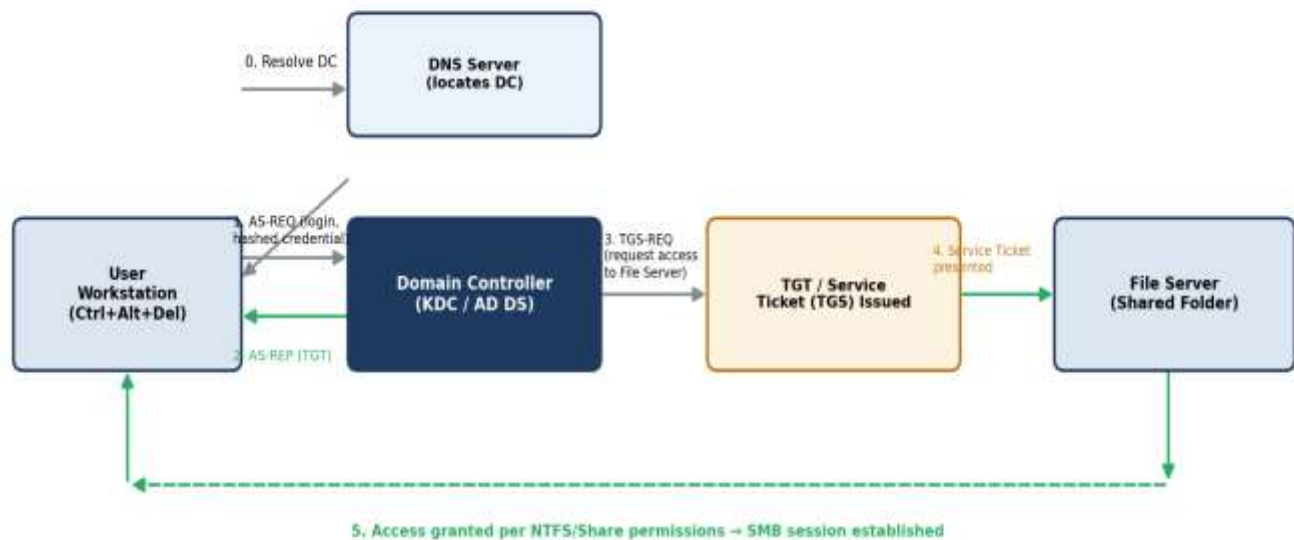


Figure 3: Kerberos authentication sequence from workstation login to file-share access.

2.5 Why Each OU Was Placed Where It Was

- Departmental OUs (HR, IT, Finance, Sales, Management): Each department is isolated into its own OU so that Group Policy Objects (GPOs) and delegated permissions can be scoped precisely — for example, a stricter USB-blocking policy can be linked only to HR/Finance/Sales without affecting IT admins who occasionally need removable media for backups.
- Servers OU: Kept separate from user OUs because servers need very different GPOs (no screen-saver lock policy, different audit settings, restricted logon rights) and must never inherit desktop-user policies.
- Workstations OU: Client machines are separated from servers so that endpoint-hardening GPOs (BitLocker, Defender, USB restriction) apply only to desktops/laptops.
- Service Accounts OU: Isolated so that "non-expiring password" exceptions and tighter monitoring can be applied only to automated/service identities, without weakening the password policy for human users.
- Top-level TechSecure-Corp OU: Acts as a container so that a single baseline GPO (e.g., password complexity, audit policy) can be linked once at the top and inherited by every child OU, reducing duplicate policy management.

2.6 How This Design Improves Security

- Delegation of control: OU boundaries let the IT-Admins group manage Servers/Workstations without being granted rights over HR or Finance user objects, enforcing separation of duties.
- Granular Group Policy scoping: Security controls (USB blocking, CMD restriction, BitLocker) can be targeted to the OUs that need them instead of a single flat policy for the whole domain, reducing both attack surface and administrative friction.
- Reduced blast radius: Because departmental OUs are distinct, a compromised account in Sales cannot be used to directly modify HR or Finance GPO-linked objects.
- Site-aware replication: Two DCs at two sites provide authentication availability if the WAN link or one site goes down, and localize authentication traffic to reduce latency and exposure across the WAN.
- Clear audit boundaries: Object-access auditing can be enabled per-OU, making log review and incident response faster because analysts already know which OU an affected object belongs to.

3. Task 2 – Users, Groups & Permission Planning

25 user accounts were created across the five departments (5 per department), 10 Security Groups were defined to control access, and 5 shared folders were configured with department-scoped permissions.

3.1 Users (25)

Full Name	Username	Dept.	Job Title	Group Membership	Access Rights
Ali Raza	ali.raza	HR	HR Manager	GG-HR-Managers, GG-HR-Staff	Modify: HR-Shared
Fatima Sheikh	fatima.sheikh	HR	HR Executive	GG-HR-Staff	Read: HR-Shared
Ayesha Malik	ayesha.malik	HR	Recruitment Officer	GG-HR-Staff	Read: HR-Shared
Sana Tariq	sana.tariq	HR	Payroll Officer	GG-HR-Staff	Modify: HR-Shared
Hina Iqbal	hina.iqbal	HR	HR Assistant	GG-HR-Staff	Read: HR-Shared
Usman Farooq	usman.farooq	IT	IT Manager / Domain Admin	GG-IT-Admins, GG-IT-Staff	Full Control: All Shares
Hamza Sheikh	hamza.sheikh	IT	System Administrator	GG-IT-Admins, GG-IT-Staff	Full Control: IT-Shared, Servers OU
Bilal Hussain	bilal.hussain	IT	Network Engineer	GG-IT-Staff, GG-Helpdesk	Modify: IT-Shared
Zainab Aslam	zainab.aslam	IT	Helpdesk Technician	GG-Helpdesk, GG-IT-Staff	Read: IT-Shared
Kashif Mehmood	kashif.mehmood	IT	Security Analyst	GG-IT-Staff	Read: All Shares (audit)
Imran Baig	imran.baig	Finance	Finance Manager	GG-Finance-Managers, GG-Finance-Staff	Full Control: Finance-Shared
Sara Yousaf	sara.yousaf	Finance	Accountant	GG-Finance-Staff	Modify: Finance-Shared
Nida Chaudhry	nida.chaudhry	Finance	Accounts Payable	GG-Finance-Staff	Modify: Finance-Shared
Mehwish Anwar	mehwish.anwar	Finance	Auditor	GG-Finance-Staff	Read: Finance-Shared

Full Name	Username	Dept.	Job Title	Group Membership	Access Rights
Faisal Nadeem	faisal.nadeem	Finance	Finance Assistant	GG-Finance-Staff	Read: Finance-Shared
Adeel Rashid	adeel.rashid	Sales	Sales Manager	GG-Sales-Staff	Modify: Sales-Shared
Rabia Siddiqui	rabia.siddiqui	Sales	Sales Executive	GG-Sales-Staff	Read: Sales-Shared
Waqas Ahmed	waqas.ahmed	Sales	Business Dev. Officer	GG-Sales-Staff, GG-VPN-Users	Read: Sales-Shared
Sadia Parveen	sadia.parveen	Sales	Customer Relations Officer	GG-Sales-Staff	Read: Sales-Shared
Farah Naz	farah.naz	Sales	Sales Coordinator	GG-Sales-Staff	Modify: Sales-Shared
Tariq Mahmood	tariq.mahmood	Management	CEO	GG-Management-Staff, GG-VPN-Users	Read: Management-Shared, Finance-Shared
Amna Riaz	amna.riaz	Management	COO	GG-Management-Staff	Modify: Management-Shared
Shahid Latif	shahid.latif	Management	Operations Director	GG-Management-Staff	Modify: Management-Shared
Noor Fatima	noor.fatima	Management	Executive Assistant	GG-Management-Staff	Read: Management-Shared
Ahmed Khan	ahmed.khan	Management	Business Analyst	GG-Management-Staff, GG-VPN-Users	Read: Management-Shared

3.2 Security Groups (10)

Group Name	Type / Scope	Members	Purpose
GG-HR-Staff	Global Security	All HR department employees	Read/Modify access to HR-Shared based on role
GG-HR-Managers	Global Security	HR managers only	Full Control delegation over HR OU objects

Group Name	Type / Scope	Members	Purpose
GG-IT-Staff	Global Security	All IT department employees	Modify/Full Control on IT-Shared, GPO management
GG-IT-Admins	Global Security	IT/System Administrators	Domain Admin-level rights, server management
GG-Finance-Staff	Global Security	All Finance department employees	Read/Modify access to Finance-Shared
GG-Finance-Managers	Global Security	Finance managers only	Full Control on Finance-Shared, approval rights
GG-Sales-Staff	Global Security	All Sales department employees	Read/Modify access to Sales-Shared
GG-Management-Staff	Global Security	Executives & senior management	Read/Modify on Management-Shared, cross-dept read
GG-VPN-Users	Global Security	Remote-access approved staff	Permission to connect via company VPN
GG-Helpdesk	Global Security	Level-1 IT support staff	Password reset & unlock rights (delegated), no data access

3.3 Shared Folders & NTFS/Share Permissions (5)

Folder	Full Control	Modify	Read	Denied Access
HR-Shared	GG-HR-Staff	GG-HR-Managers	GG-IT-Admins (custodian)	GG-Sales-Staff, GG-Finance-Staff, GG-Management-Staff
Finance-Shared	GG-Finance-Managers (view-only extract), Tariq Mahmood (CEO)	GG-Finance-Staff	GG-Finance-Managers, GG-IT-Admins	GG-HR-Staff, GG-Sales-Staff, GG-Helpdesk
IT-Shared	GG-IT-Staff	GG-IT-Staff	GG-IT-Admins	GG-HR-Staff, GG-Finance-Staff, GG-Sales-Staff
Sales-Shared	GG-Sales-Staff, GG-Management-Staff	GG-Sales-Staff	GG-IT-Admins	GG-HR-Staff (except HR Managers), GG-Helpdesk
Management-Shared	GG-Management-Staff	GG-Management-Staff (senior only)	GG-IT-Admins, CEO account	All other GGs (Sales, HR, Finance, Helpdesk)

3.42.7 Answers – Account Targeting & Least Privilege

Which account would attackers target first, and why?

The account most likely to be targeted first is usman.farooq (IT Manager / Domain Admin). This account combines Domain Admin-equivalent rights (via GG-IT-Admins) with Full Control over all file shares, making it the single highest-value target: compromising it grants an attacker the ability to create/modify accounts, reset any password, access all departmental data, and push malicious Group Policy to every machine in the domain. Attackers typically pursue such accounts through phishing, credential dumping (e.g., Mimikatz after an initial foothold), or Kerberoasting service accounts that share privileged group membership.

A close second target is tariq.mahmood (CEO), because executive accounts are common targets of Business Email Compromise (BEC) and spear-phishing due to their financial-approval authority and typically broad, cross-department read access.

Which permissions violate the Least Privilege Principle?

- kashif.mehmood (Security Analyst) is granted Read access to "All Shares" for audit purposes — broad, standing access across every department is unnecessary; audit access should be just-in-time or scoped per investigation.
- tariq.mahmood (CEO) has standing Read access to Finance-Shared in addition to Management-Shared — an executive should not need blanket, permanent access to the full Finance repository when specific reports could be shared on request.
- GG-IT-Staff (a large, general group) is granted Modify rights on IT-Shared as a whole rather than splitting rights between junior helpdesk staff (who should only need Read) and senior engineers (who need Modify).
- hamza.sheikh (System Administrator) holds Full Control on IT-Shared and the Servers OU simultaneously through a single flat role rather than through separate, task-specific delegated roles.

How would you fix those permissions?

- Replace kashif.mehmood's standing "Read: All Shares" with a dedicated GG-Security-Auditors group that is granted time-bound, logged access only during an active investigation (Just-Enough-Administration / temporary group membership).
- Remove the CEO's direct Read grant on Finance-Shared; instead, publish a curated "Finance-Reports" sub-folder with only board-level summaries, or route ad-hoc requests through the Finance Manager.
- Split GG-IT-Staff into GG-Helpdesk (Read only) and GG-IT-Engineers (Modify), so junior technicians cannot alter shared IT documentation or scripts.
- Use role-based delegation (Delegation of Control Wizard) to separate "server management" rights from "file-share management" rights so a single compromised credential does not expose both domains of control.

4. Task 3 – Group Policy & Security Configuration

Ten Group Policy Objects (GPOs) were designed to harden TechSecure Solutions' Windows environment. Each policy below states the requirement, its scope, and the attack technique it primarily mitigates.

Group Policy	Why It Is Required / Configuration	Affected Users / OU	Attack(s) Prevented
Password Complexity Policy	Enforces minimum 12 characters, mix of upper/lower/number/symbol, 24-password history	All domain users	Brute-force attacks, dictionary attacks, credential stuffing
Account Lockout Policy	Locks account for 30 minutes after 5 failed logon attempts	All domain users	Brute-force and password-spraying attacks
Disable USB Storage (Removable Media)	Blocks removable storage class devices via GPO device restriction	All standard users (excludes IT-Admins OU)	Data exfiltration, USB-borne malware (e.g., BadUSB)
Restrict Command Prompt & PowerShell	Disables cmd.exe and restricts PowerShell execution policy for standard users	HR, Finance, Sales, Management OUs	Living-off-the-land attacks, unauthorized script execution
Enable Windows Defender Firewall	Enforces domain, private, and public firewall profiles with logging	All workstations and servers	Unauthorized inbound connections, lateral movement, port scanning
Automatic Updates (WSUS)	Forces scheduled installation of critical/security patches	All domain-joined machines	Exploitation of known/unpatched CVEs
Interactive Logon: Screen Lock	Locks screen after 5 minutes of inactivity, requires re-authentication	All standard users	Unauthorized physical access / session hijacking (insider threat)
BitLocker Drive Encryption	Enforces full-disk encryption on all laptops and removable drives	Sales & Management (mobile/traveling staff)	Data theft from lost or stolen devices
Windows Defender Antivirus / ASR Rules	Enables real-time protection, cloud-delivered protection, and Attack Surface Reduction rules	All endpoints	Malware, ransomware, fileless attacks

Group Policy	Why It Is Required / Configuration	Affected Users / OU	Attack(s) Prevented
Advanced Audit Policy (Logon/Object Access)	Enables logging for logon events, account management, and object access, forwarded to a central log server	All domain controllers and file servers	Undetected intrusion, insider misuse, supports forensic investigation



5. Task 4 – Active Directory (Windows Server)

5.1 Create one Organizational Unit

Server Manager → Active Directory Users and Computers (ADUC) → right-click domain → New → Organizational Unit → name it (e.g., "Pilot-OU").

5.2 Create five users

Within the new OU → New → User for each of five accounts; set initial password and "User must change password at next logon".

5.3 Create two security groups

New → Group → Group scope: Global, Group type: Security (e.g., GG-Pilot-Staff, GG-Pilot-Admins).

5.4 Join one Windows client to the domain

On the client: System Properties → Change → Member of: Domain → enter techsecure.local → supply domain admin credentials → restart.

5.5 Add users to groups

Select a user → Properties → Member Of tab → Add → type group name → OK.

5.6 Create one shared folder

On the file server, create a folder → right-click → Properties → Sharing tab → Advanced Sharing → Share this folder.

5.7 Apply permissions

Security tab (NTFS) and Sharing → Permissions (SMB): grant the pilot groups the intended Read/Modify rights; remove "Everyone" if present.

5.8 Reset one user's password

ADUC → right-click user → Reset Password → set temporary password → tick "User must change password at next logon".

5.9 Disable one user account

ADUC → right-click user → Disable Account (account icon shows a red down-arrow when disabled).

5.10 Unlock one locked account

ADUC → right-click the locked user → Properties → Account tab → tick "Unlock account" → OK.

6. Task 5 – Basic Kali Linux Enumeration

Command Used	Purpose	Information Revealed	Why It Matters to Defenders
<code>nmap -sn 192.168.1.0/24</code>	Ping sweep of the subnet	Live hosts on the network (including the DC and file server)	Defenders learn which hosts are reachable and should verify no unauthorized devices appear
<code>nmap -sV -p- 192.168.1.10</code>	Full TCP port scan with service/version detection against DC01	Open ports and running services (e.g., 53-DNS, 88-Kerberos, 389-LDAP, 445-SMB, 3389-RDP)	Reveals the attack surface; defenders can close/firewall unnecessary ports
<code>nslookup techsecure.local</code>	Basic DNS resolution query	Confirms the domain resolves and which IP answers for it	Detects DNS misconfiguration or unauthorized DNS entries
<code>dig SRV _ldap._tcp.dc._msdcs.techsecure.local</code>	DNS SRV record lookup for LDAP service	Identifies the exact hostname/IP of the Domain Controller via AD's self-registered SRV records	Confirms whether DC discovery records are exposed as expected, or leaking to untrusted networks
<code>enum4linux-ng -A 192.168.1.10</code>	Automated SMB/AD enumeration (shares, users, groups, policies)	Available SMB shares, password policy, OS version, and (if null sessions allowed) user/group listings	Shows defenders exactly what an unauthenticated attacker could learn, e.g. whether null-session/anonymous SMB access is misconfigured

6.1 Summary for Defenders

- If SMB null sessions or anonymous LDAP binds are found, disable them immediately — they leak usernames and password policy to unauthenticated attackers.

- Any unnecessary open ports discovered by nmap should be closed at the host firewall and, where possible, at the network firewall/VLAN boundary.
- DNS SRV records that reveal the Domain Controller should only be resolvable from internal/trusted networks — exposing internal DNS zones externally is a reconnaissance risk.
- Regularly run the same enumeration tools defenders' own systems, from an authorized internal host, to see the network the way an attacker would ("assume breach" mindset).



7. Task 6 – Case Study & Troubleshooting

Scenario: A user reports they cannot log in to the domain, their password was changed yesterday, and they also cannot access the shared HR folder.

7.1 Ten Possible Causes

1. The password change did not replicate yet from DC01 to DC02 (AD replication delay/failure).
2. The user is authenticating against a stale cached credential on the workstation.
3. The account is locked out due to repeated failed logon attempts (old password cached somewhere, e.g., a mapped drive or mobile device).
4. Time skew between the client and the Domain Controller is breaking Kerberos authentication (more than 5 minutes' difference).
5. The user's account was accidentally disabled during the password reset.
6. DNS on the client is misconfigured, so the workstation cannot locate a Domain Controller at all.
7. A Group Policy applied at logon is failing, blocking the session before the desktop loads.
8. The user's NTFS/Share permissions on the HR folder were not updated after a recent group membership change.
9. The HR shared folder's security group (GG-HR-Staff) lost the user as a member during the same change window.
10. Physical or VPN network connectivity to the domain/file server is down for that workstation.

7.2 Step-by-Step Troubleshooting

1. Confirm the exact error message shown at logon (wrong password, account locked, trust relationship failed, etc.) — this immediately narrows the cause.
2. Verify the account status in ADUC: check whether it is locked or disabled, and unlock/enable if required.
3. Check AD replication health between DC01 and DC02 using `repadmin /replsummary` and `repadmin /showrepl` to rule out a stale password copy on the DC that authenticated the user.
4. Verify the workstation's DNS settings (`ipconfig /all`) point to an internal DNS server that can resolve the domain, and confirm `nslookup techsecure.local` succeeds.
5. Check the system clock on the client versus the DC (`w32tm /query /status`) — Kerberos fails if skew exceeds 5 minutes.
6. Have the user log on to a different, known-good workstation with the new password to isolate whether the issue is the account or the original machine.
7. Review the user's group membership in ADUC → Member Of, and confirm GG-HR-Staff is still listed after the recent change.
8. Check NTFS and Share permissions on the HR-Shared folder to confirm GG-HR-Staff still has the intended Read/Modify entries.
9. Run `gpupdate /force` and `gpresult /r` on the client to confirm Group Policy applied correctly and no logon-restriction GPO is blocking the session.
10. If all else checks out, reset the password again in ADUC and have the user retry, in case the original change did not commit cleanly.

7.3 Active Directory Components to Check

- Domain Controller(s) – DC01 (FSMO holder) and DC02 (replication partner)
- AD DS replication topology and site links
- DNS zone records for the domain and the SRV records used for DC discovery
- Kerberos Key Distribution Center (KDC) service on the DC
- Group Policy Objects linked to the user's OU
- Security group membership (GG-HR-Staff) and the NTFS/Share ACLs on the HR folder

7.4 Windows Logs to Review

- Security log (Event ID 4625 – failed logon, 4740 – account lockout, 4720/4738 – account changes) on the DC
- Directory Service log for replication errors
- DNS Server log for resolution failures
- System log on the client for Netlogon and Kerberos errors (e.g., Event ID 5719)

7.5 Verifying DNS, Group Policy, and Kerberos

- DNS: run `nslookup techsecure.local` and `nslookup -type=SRV _ldap._tcp.dc._msdcs.techsecure.local` from the client; both should resolve to a valid, reachable DC.
- Group Policy: run `gpresult /h gpreport.html` on the client to view exactly which GPOs applied and whether any failed, and confirm no policy is denying interactive logon for the user's group.
- Kerberos: run `klist` to check for a valid ticket after logon, and confirm the client/DC time difference is within the 5-minute tolerance using `w32tm /query /status`.

7.6 Final Incident Report

Field	Details
Incident	User unable to log in to the domain and unable to access the HR shared folder following a password change.
Root Cause	The user's group membership (GG-HR-Staff) was inadvertently removed during the password-reset/account-update process, and a brief AD replication delay meant the new password had not yet reached DC02 when the user first attempted logon from the branch office.
Impact	Temporary loss of productivity for one HR user; no data was exposed or altered.
Resolution	Confirmed replication had completed (<code>repadmin /replsummary clean</code>), re-added the user to GG-HR-Staff, ran <code>gpupdate /force</code> on the client, and verified successful logon and HR-Shared access.
Preventive Action	Introduced a checklist step for HR account changes requiring group-membership verification, and added a monitoring alert for AD replication delays exceeding 15 minutes.

8. Challenges Faced

- Balancing least-privilege access with the practical need for department managers to view cross-department summaries (e.g., the CEO needing Finance visibility).
- Deciding the right granularity for OUs and groups so that GPOs stay easy to manage without becoming too fragmented.
- Ensuring the Kali Linux enumeration stayed strictly within the isolated lab and did not touch any live or public infrastructure.

9. Conclusion

This assignment reinforced core Active Directory concepts — forest/domain/OU design, role-based group management, Group Policy hardening, and Kerberos authentication — while applying them to a realistic 300-user enterprise scenario. Designing the environment around the Principle of Least Privilege and defense-in-depth (network segmentation, GPO hardening, auditing, and encryption) demonstrated how a Cyber Security Analyst plans for both usability and resilience against common attack techniques such as brute-forcing, credential theft, and unauthorized data access. The troubleshooting case study further highlighted the importance of methodical, log-driven diagnosis when authentication issues span multiple AD components.

